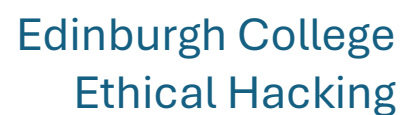


Mohamed Abozziane EC1713487

Mohamed Abozziane EC1713487



Edinburgh College
Ethical Hacking

Contents

ETHICAL HACKING PRACTICAL ASSESSMENT REPORT	2
Executive Summary.....	2
Findings and Remediation Overview	3
Methodology	4
Conclusion.....	5
Details and evidence of the test	6
Tools Used	6
Reconnaissance Evidence	6
Enumeration Evidence	12
Vulnerability Summary Table.....	16
Risk Rating Methodology	16
Rule: Countermeasure retesting	16
Maintaining the access	18
Covering Tracks	18

ETHICAL HACKING PRACTICAL ASSESSMENT REPORT

Student Name: *Mohamed Abozziane*

Student Number: *EC1713487*

Unit: J0HK 34 – Ethical Hacking

Assessment: Practical Assessment

Date: *20/01/2026*

Target System: Metasploitable 2 (192.168.15.12)

Tester System: Kali Linux (192.168.15.10)

Executive Summary

This penetration test was organized in order to determine the strength of the internal Research and Development area in the ESN corporation, since the company aims to expand in the Asian markets.

With the increase in the global spread of ESN, the organization faces a wider range of threats from different sources. The R&D team deals with valuable IPR, prototype development, and other clients' solutions, making it the primary target for hackers.

These problems could be addressed in advance through a controlled pen test using VMware in an isolated environment. The environment was set up in Kali Linux, with the purpose-built Metasploitable 2 software running on the internal R&D server. The intention was to identify vulnerabilities, assess the risk and proposed impact on the company, and provide recommendations on advancements in the field that would make ESN prepared for the future.

There were some weaknesses discovered during the testing process, including outdated services, anonymous login functionality, insecure communication protocols, and misconfigured settings. While the testing process was conducted in a safe manner and no harm was incurred, it has become quite clear that the type of attacks ESN would receive in the live environment would be exhibited through the findings.

The effectiveness of each countermeasure was tested, and the first two have worked well in the environment, proving that quick and efficient solutions can be implemented against the problem. In closing, the following report outlines the results, describes the proper procedure, and provides guidance on ensuring ESN maintains a solid security posture in the growing global organization.

Findings and Remediation Overview

The audit identified vulnerabilities comprising both high-risk and medium-risk issues that could result in detrimental damage to ESN's functionalities and security in case the vulnerabilities are exploited. One of the issues identified in the audit report as posing the highest threats to ESN's security was the anonymous FTP access in which people could gain access to the FTP server and browse through the documents without needing any login or password requirements. It was posed as the main weakness in the configuration since it offers attackers several avenues through which they can acquire information regarding the target. Additionally, there was evidence of SMB null sessions, meaning that unauthorized users had the capability to connect to the network shares whose settings promoted overly permissive "guest" rights. These issues tend to offer information regarding the directory structure of the identified system, the user accounts, and other in-house computer systems.

One of the most important aspects was using outdated services. Just take, for example, using the outdated version of the Apache server. Using outdated services such as OpenSSH and other services in the back end poses critical risk because it makes it easier than ever for the hacker to carry out remote code execution and gain privileges. Using Telnet, an outdated protocol, was also checked. It poses critical risk because the protocol enables plaintext auth, and the auth can be intercepted.

The remediation process should happen in two stages. To reduce attacks in the preliminary stages, the organization must disable anonymous connections, cut back the number of guest login accounts, remove any unnecessary services, and begin using secure configuration baselines. In carrying out the process of penetration test identification, there are two issues identified and addressed, and they are disabling anonymous FTP and limiting SMB guest connectivity. To eradicate threats in the long run, ESN must address issues concerning patch management, utilization of encrypting protocols, removal of outdated software, and segmentation of networks. These remediation actions shall help cover the protection of the data in the R&D department.

Methodology

There was a structured way the penetration test was conducted. The test was conducted in a manner that involved reconnaissance, in which the attacker's computer determined the basic network information using commands such as "ip a" in order to scan the settings, and then using netdiscover in order to test the live systems on the network. The attacking system was then able to identify the targeted host, which was 192.168.15.12. ICMP ping attempts would then be made in an effort to determine whether the host could be accessed.

The technical penetration test involved enumeration. Nmap scans assisted in the detection of open ports, running services, and software versions through service, version detection, and information gathering scripts. WhatWeb was utilized in detecting web services. Nikto assisted in the detection of old and insecure settings on the web server. SMBClient and Enum4linux were applied in the test of SMB shares and the Authentication process, detecting critical misconfigurations such as the null session. In the process of enumeration, all the scans performed were conducted in a safe manner, in compliance with the ethical aspects relevant in the technical agreement.

The process was then followed by a safe proof-of-exploit step, where the weaknesses were proven by performing harmless exploitation. This would include, for example, testing the anonymous FTP login by simply connecting to the service without credentials and then checking the SMB null session by viewing the shared resources. There would be no malicious payloads, privilege escalation, or destructive testing because the intention was simply to prove the weaknesses exist.

The test also involved discussions on keeping access and hidden the activities. The notes were written in such a manner that they could identify the actions taken by the attackers without posing harm. Finally, after using the two countermeasures, the test was conducted to make sure the services that were prone to threats could not be accessed anymore.

A Netcat command was employed that could connect the shell to the TCP port. The general format that the command would ideally take, in order to send and receive data over the network, facilitating execution, has been discovered.

Conclusion

Pen test revealed weaknesses in the mock R&D environment provided by ESN. The systems, in their present forms, could potentially be subject to an intrusion with unauthorized access, data breaches, and service disruptions.

The issues discovered in the test were problems such as anonymous login, inappropriate settings, outdated software, and outdated protocols. These issues prove why having an up-to-date proactive cybersecurity strategy in the organization is essential. Although the issues are in the simulated test environment, problems like these are still present in the organization because they are integrating technology into their operations.

However, the ethical test also states that ESN has a great foundation on which they can work in order to improve their security. The ability for the countermeasures to effectively work during the test means that the problems founded can indeed be solved when the necessary measures are put in place on time. In order for ESN to remain safe in the long term, they need to implement the recommendations placed above by the report. These include frequent patches, secure settings, the elimination of unnecessary services, constant monitoring, and enforcement of stringent settings. Penetration testing ought to be part of the security measures employed by ESN, particularly when they are venturing into other markets and adopting different technologies.

Details and evidence of the test

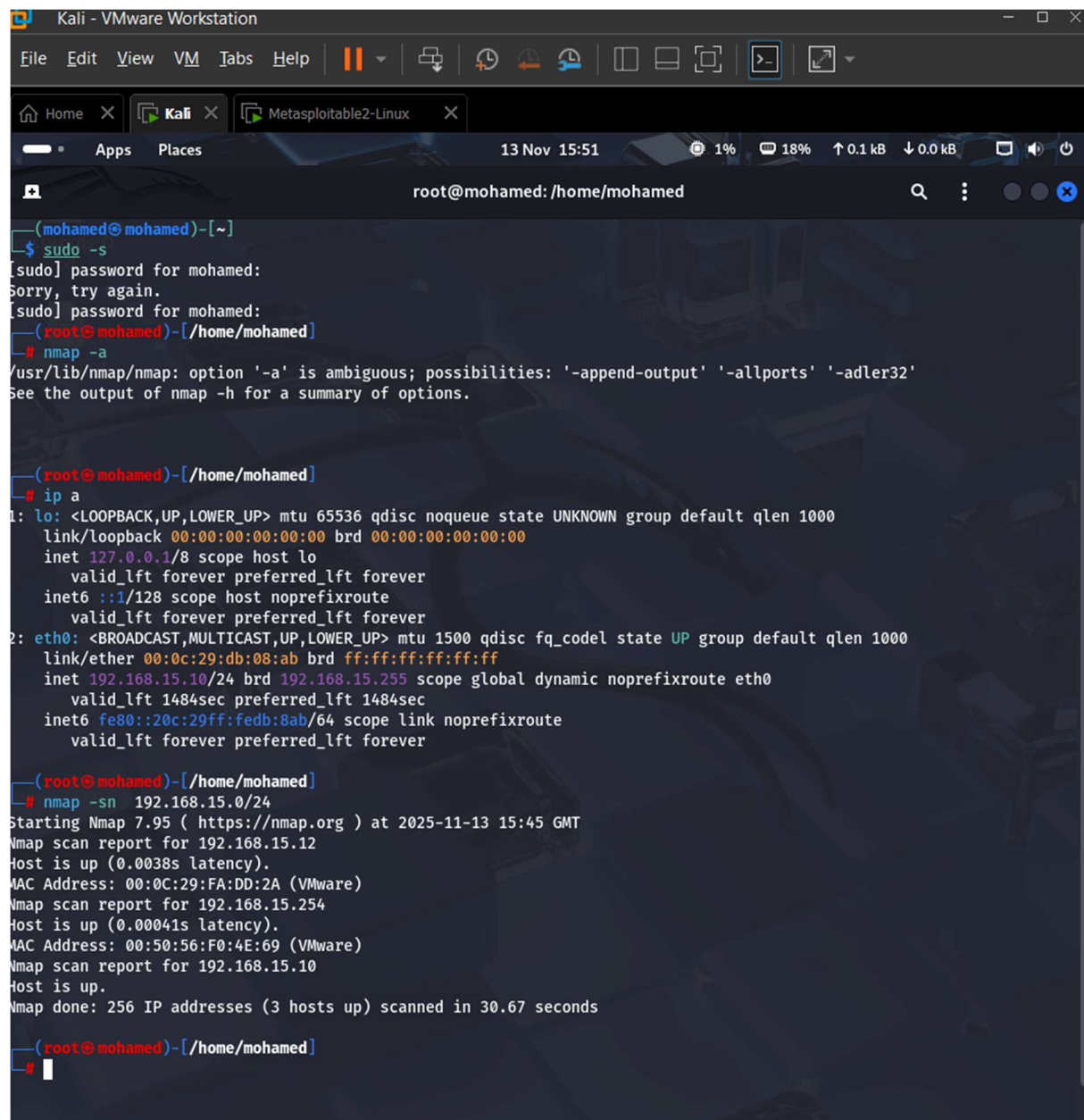
Tools Used

For the task of penetration, many conventional Kali Linux tools were employed. Each tool played a distinct role in the reconnaissance and enumeration phase. Nmap was particularly effective in listing networks, port scanning, and service discovery. It possessed vast versatility and scripting capabilities, which helped in the detection of openly accessible services, outdated versions, and complex environments. Netdiscover was utilized to discover hosts in the VMware sub-network and check the availability of the target computer. These tools helped acquire preliminary knowledge about the surroundings and facilitated further analysis at the latter stage. Online tools like WhatWeb and Nikto aided in uncovering both the services and the vulnerabilities related to the HTTP service at the target computer. WhatWeb disclosed the technologies employed, whereas Nikto disclosed outdated or week vulnerabilities in the target computer's server. SMBClient and Enum4Linux facilitated an understanding of both the SMB shares as well as the process of computer authentication. These tools combined helped conduct secure ethical hacking

Reconnaissance Evidence

Reconnaissance In reconnaissance, tasks involved targeting and confirming the existence of the target computer. For the attacking computer, an ip/a scan was performed to discover IP addresses of the attacking computer and found to belong to the range of 192.168.15.0/24. Next, the discovery of the computer in the internal network was accomplished using the command `netdiscover -r 192.168.15.0/24`, where the computer at 192.168.15.12 was detected as the target computer. To verify the existence or functionality of the computer, `ping -c 4 192.168.15.12` was run successfully in the command line. These tasks assure network connectivity and form the basics of further explorations. These tasks are elementary but highlight the beginning of an advanced penetration test since the network scan configuration has already been tested and ready to proceed to further complex tasks.

I've also used the Nessus reconnaissance method by downloading it on my local machine on Kali Linux and used the Scan discovery method to the whole network. By using this method, I have discovered several critical vulnerabilities on the IP target. The points such VNC Service; for the password, General system not updated, SSL version 2 and 3 protocol, Request Injection for the Web Server and the Bind Shell for the backdoors, was detected as critical vulnerabilities, which are the essentials point for a future cyberattack.



The screenshot shows a Kali Linux terminal window titled 'Kali - VMware Workstation'. The terminal is running as root at the mohamed user's home directory. The user attempts to run 'sudo -s' but fails to provide a password. Then, they run 'nmap -a', which displays an error about an ambiguous option '-a'. Next, they run 'ip a' to show network interface details for 'lo' and 'eth0'. Finally, they run 'nmap -sn 192.168.15.0/24', which performs a host discovery scan on the 192.168.15.0/24 network, reporting that three hosts are up.

```
(mohamed@mohamed)-[~]
$ sudo -s
[sudo] password for mohamed:
Sorry, try again.
[sudo] password for mohamed:
(root@mohamed)-[/home/mohamed]
# nmap -a
/usr/lib/nmap/nmap: option '-a' is ambiguous; possibilities: '-append-output' '-allports' '-adler32'
See the output of nmap -h for a summary of options.

(root@mohamed)-[/home/mohamed]
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:db:08:ab brd ff:ff:ff:ff:ff:ff
    inet 192.168.15.10/24 brd 192.168.15.255 scope global dynamic noprefixroute eth0
        valid_lft 1484sec preferred_lft 1484sec
    inet6 fe80::20c:29ff:fedb:8ab/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(root@mohamed)-[/home/mohamed]
# nmap -sn 192.168.15.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-13 15:45 GMT
Nmap scan report for 192.168.15.12
Host is up (0.0038s latency).
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Nmap scan report for 192.168.15.254
Host is up (0.00041s latency).
MAC Address: 00:50:56:F0:4E:69 (VMware)
Nmap scan report for 192.168.15.10
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 30.67 seconds

(root@mohamed)-[/home/mohamed]
#
```



```
Nmap scan report for 192.168.15.12
Host is up (0.0035s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:FA:DD:2A (VMware)

Nmap scan report for 192.168.15.254
Host is up (0.00079s latency).
All 1000 scanned ports on 192.168.15.254 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:50:56:FC:6D:1A (VMware)

Nmap scan report for 192.168.15.10
Host is up (0.0000070s latency).
All 1000 scanned ports on 192.168.15.10 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 256 IP addresses (3 hosts up) scanned in 34.96 seconds

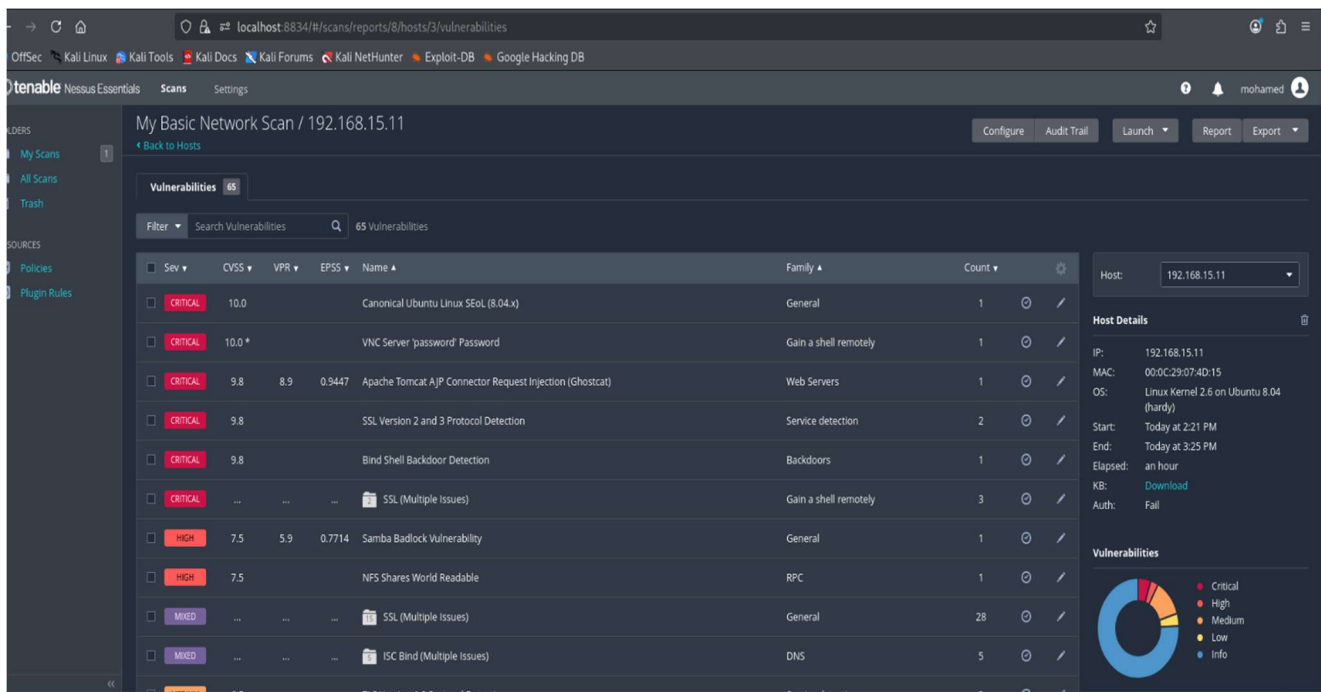
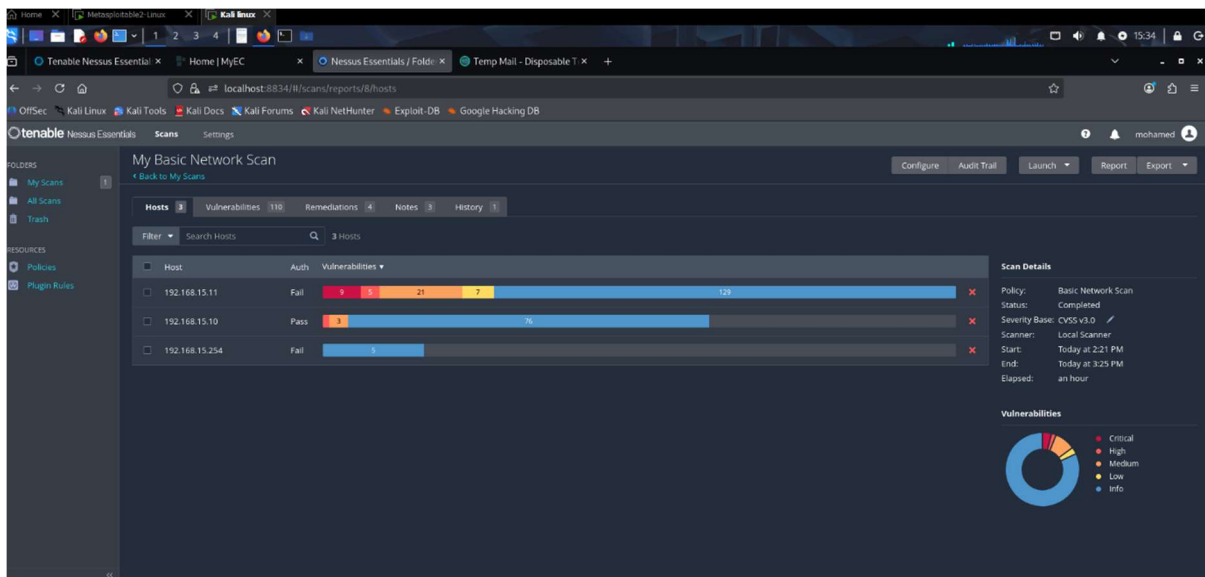
(mohamed@mohamed)-[~]
$
```

```
Home X Kali X Metasploitable2-Linux X
Apps Places 26 Nov 16:19 1% 17% ↑ 0.1 kB ↓ 0.0 kB
mohamed@mohamed: ~
| 100024 1 51594/tcp status
|_ 100024 1 53902/udp status
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec netkit-rsh rexecd
513/tcp open login?
514/tcp open shell Netkit rshd
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
| mysql-info:
| Protocol: 10
| Version: 5.0.51a-3ubuntu5
| Thread ID: 15
| Capabilities flags: 43564
| Some Capabilities: SwitchToSSLAfterHandshake, Support41Auth, LongColumnFlag, SupportsTransactions, Speaks41Protoc
olNew, SupportsCompression, ConnectWithDatabase
| Status: Autocommit
|_ Salt: <-iN(|]9G7}2-H*:$CgZ
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no suc
h thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2025-11-26T16:13:29+00:00; +5s from scanner time.
5900/tcp open vnc VNC (protocol 3.3)
| vnc-info:
| Protocol version: 3.3
| Security types:
|_ VNC Authentication (2)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
```

The image shows two screenshots. The top screenshot is a terminal window titled 'mohamed@mohamed: ~' displaying the output of an ARP scan. It shows 'Currently scanning: Finished!' and 'Screen View: Unique Hosts'. Below this, it states 'Captured ARP Req/Rep packets, from 2 hosts. Total size: 120'. A table follows with columns: IP, At MAC Address, Count, Len, MAC Vendor / Hostname. The table contains two rows of data for IP addresses 192.168.15.12 and 192.168.15.254, both with MAC address 00:50:56:fc:6d:1a and identified as VMware, Inc.

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.15.12	00:50:56:fc:6d:1a	1	60	VMware, Inc.
192.168.15.254	00:50:56:fc:6d:1a	1	60	VMware, Inc.

The bottom screenshot shows the Nessus web interface. The 'My Scans' section is active, displaying a 'My Host Discovery Scan Results' dialog box. The dialog box states: 'Nessus found the following hosts listed below from your list of targets (192.168.15.0/24). To launch your first basic network scan, select the hosts you want to scan. These hosts count towards the 5 host limit on your license.' It lists three hosts: 192.168.15.10, 192.168.15.11, and 192.168.15.254, each with a checkbox. The 'Discovering Hosts...' progress indicator is shown at the bottom of the dialog. The background interface shows the 'My Scans' section with a message 'This folder is empty. Create a new scan.' and a sidebar with 'My Scans', 'All Scans', and 'Trash'.



Enumeration Evidence

One of the most important pieces of information gathered during the Enumeration phase was obtained from the Enumeration itself. Full port scan using the command “nmap -A 192.168.15.12” identified the following services: FTP (port 21), SSH (port 22), Telnet (port 23), HTTP (port 80), and SMB (ports 139 & 445). All these services had outdated versions that could easily be attacked. For example, the FTP service was using vsftpd version 2.3.4, which allows anonymous login when the “default anonymity rules” option is turned off. Again, the Apache web server responded with headers indicating Apache version 2.2.8, which was prone to numerous known vulnerabilities in the past.

By using smbclient -L //192.168.15.12 -N, there was further information obtained about the SMB service, including null session authentication, which means that any user can connect to shared resources without cost. By using enum4linux -a 192.168.15.12, further data was obtained regarding the users, groups, and the shared resources. Although these services are exposed, the data obtained illustrates issues in configuration that real-world companies must not have.

```
(mohamed@mohamed)-[~]
$ nc 192.168.15.12 80
hi this is a test from mohamed
^C

(mohamed@mohamed)-[~]
$ nc 192.168.15.12 22
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
hi this is a test from Mohamed
Protocol mismatch.

(mohamed@mohamed)-[~]
$ nc 192.168.15.12 23
hi this is a test from Mohamed
^C

(mohamed@mohamed)-[~]
$ nc 192.168.15.12 21
220 (vsFTPd 2.3.4)
hi this is test from Mohamed
530 Please login with USER and PASS.
^C

(mohamed@mohamed)-[~]
$
```



```

(mohamed@ mohamed)~]
$ sudo nmap -sV 192.168.15.12
[sudo] password for mohamed:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-26 16:22 GMT
Nmap scan report for 192.168.15.12
Host is up (0.0049s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 65.85 seconds

(mohamed@ mohamed)~]
$

```

```

(mohamed@ mohamed)~]
$ enum4linux -a 192.168.15.12
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Nov 26 18:34:13 2025

===== ( Target Information ) =====
Target ..... 192.168.15.12
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.15.12 ) =====

[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.15.12 ) =====

Looking up status of 192.168.15.12
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
.._MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections

MAC Address = 00-00-00-00-00-00

===== ( Session Check on 192.168.15.12 ) =====

[+] Server 192.168.15.12 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.15.12 ) =====

Domain Name: WORKGROUP
Domain Sid: (NULL SID)

```

```
Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup

===== ( OS information on 192.168.15.12 )=====

[E] Can't get OS info with smbclient

[+] Got OS info for 192.168.15.12 from srvinfo:
METASPLOITABLE Wk Sv PrQ Unx NT SNT metasploitable server (Samba 3.0.20-Debian)
platform_id      :      500
os version       :      4.9
server type      :      0x9a03

===== ( Users on 192.168.15.12 )=====

index: 0x1 RID: 0x3f2 acb: 0x00000011 Account: games      Name: games      Desc: (null)
index: 0x2 RID: 0x1f5 acb: 0x00000011 Account: nobody   Name: nobody     Desc: (null)
index: 0x3 RID: 0x4ba acb: 0x00000011 Account: bind     Name: (null)     Desc: (null)
index: 0x4 RID: 0x402 acb: 0x00000011 Account: proxy    Name: proxy      Desc: (null)
index: 0x5 RID: 0x4b4 acb: 0x00000011 Account: syslog   Name: (null)     Desc: (null)
index: 0x6 RID: 0xbba acb: 0x00000010 Account: user     Name: just a user,111,, Desc: (null)
index: 0x7 RID: 0x42a acb: 0x00000011 Account: www-data Name: www-data   Desc: (null)
index: 0x8 RID: 0x3e8 acb: 0x00000011 Account: root     Name: root       Desc: (null)
index: 0x9 RID: 0x3fa acb: 0x00000011 Account: news     Name: news       Desc: (null)
index: 0xa RID: 0x4c0 acb: 0x00000011 Account: postgres Name: PostgreSQL administrator,,, Desc: (null)
index: 0xb RID: 0x3ec acb: 0x00000011 Account: bin      Name: bin        Desc: (null)
index: 0xc RID: 0x3f8 acb: 0x00000011 Account: mail     Name: mail       Desc: (null)
index: 0xd RID: 0x4c6 acb: 0x00000011 Account: distccd  Name: (null)     Desc: (null)
index: 0xe RID: 0x4ca acb: 0x00000011 Account: proftpd  Name: (null)     Desc: (null)
index: 0xf RID: 0x4b2 acb: 0x00000011 Account: dhcp     Name: (null)     Desc: (null)
index: 0x10 RID: 0x3ea acb: 0x00000011 Account: daemon   Name: daemon     Desc: (null)
index: 0x11 RID: 0x4b8 acb: 0x00000011 Account: sshd     Name: (null)     Desc: (null)
index: 0x12 RID: 0x3f4 acb: 0x00000011 Account: man      Name: man        Desc: (null)
index: 0x13 RID: 0x3f6 acb: 0x00000011 Account: lp       Name: lp         Desc: (null)
index: 0x14 RID: 0x4c2 acb: 0x00000011 Account: mysql    Name: MySQL Server,,, Desc: (null)
index: 0x15 RID: 0x42a acb: 0x00000011 Account: gate     Name: Gate Bus Reporting System (admin) Desc: (null)
```

```
1-5-21-1042354039-2475377354-766472396-512 METASPLOITABLE\Domain Admins (Domain Group)
1-5-21-1042354039-2475377354-766472396-513 METASPLOITABLE\Domain Users (Domain Group)
1-5-21-1042354039-2475377354-766472396-514 METASPLOITABLE\Domain Guests (Domain Group)
1-5-21-1042354039-2475377354-766472396-1000 METASPLOITABLE\root (Local User)
1-5-21-1042354039-2475377354-766472396-1001 METASPLOITABLE\root (Domain Group)
1-5-21-1042354039-2475377354-766472396-1002 METASPLOITABLE\daemon (Local User)
1-5-21-1042354039-2475377354-766472396-1003 METASPLOITABLE\daemon (Domain Group)
1-5-21-1042354039-2475377354-766472396-1004 METASPLOITABLE\bin (Local User)
1-5-21-1042354039-2475377354-766472396-1005 METASPLOITABLE\bin (Domain Group)
1-5-21-1042354039-2475377354-766472396-1006 METASPLOITABLE\sys (Local User)
1-5-21-1042354039-2475377354-766472396-1007 METASPLOITABLE\sys (Domain Group)
1-5-21-1042354039-2475377354-766472396-1008 METASPLOITABLE\sync (Local User)
1-5-21-1042354039-2475377354-766472396-1009 METASPLOITABLE\adm (Domain Group)
1-5-21-1042354039-2475377354-766472396-1010 METASPLOITABLE\games (Local User)
1-5-21-1042354039-2475377354-766472396-1011 METASPLOITABLE\tty (Domain Group)
1-5-21-1042354039-2475377354-766472396-1012 METASPLOITABLE\man (Local User)
1-5-21-1042354039-2475377354-766472396-1013 METASPLOITABLE\disk (Domain Group)
1-5-21-1042354039-2475377354-766472396-1014 METASPLOITABLE\lp (Local User)
1-5-21-1042354039-2475377354-766472396-1015 METASPLOITABLE\lp (Domain Group)
1-5-21-1042354039-2475377354-766472396-1016 METASPLOITABLE\mail (Local User)
1-5-21-1042354039-2475377354-766472396-1017 METASPLOITABLE\mail (Domain Group)
1-5-21-1042354039-2475377354-766472396-1018 METASPLOITABLE\news (Local User)
1-5-21-1042354039-2475377354-766472396-1019 METASPLOITABLE\news (Domain Group)
1-5-21-1042354039-2475377354-766472396-1020 METASPLOITABLE\uucp (Local User)
1-5-21-1042354039-2475377354-766472396-1021 METASPLOITABLE\uucp (Domain Group)
1-5-21-1042354039-2475377354-766472396-1025 METASPLOITABLE\man (Domain Group)
1-5-21-1042354039-2475377354-766472396-1026 METASPLOITABLE\proxy (Local User)
1-5-21-1042354039-2475377354-766472396-1027 METASPLOITABLE\proxy (Domain Group)
1-5-21-1042354039-2475377354-766472396-1031 METASPLOITABLE\kmem (Domain Group)
1-5-21-1042354039-2475377354-766472396-1041 METASPLOITABLE\dialout (Domain Group)
1-5-21-1042354039-2475377354-766472396-1043 METASPLOITABLE\fax (Domain Group)
1-5-21-1042354039-2475377354-766472396-1045 METASPLOITABLE\voice (Domain Group)
1-5-21-1042354039-2475377354-766472396-1049 METASPLOITABLE\cdrom (Domain Group)

===== ( Getting printer info for 192.168.15.12 )=====

0 printers returned.

num4linux complete on Wed Nov 26 18:34:23 2025

-(mohamed@mohamed)-[~]
$
```



```
(mohamed@moahmed)-[~]
$ whatweb http://192.168.15.12
http://192.168.15.12 [200 OK] Apache[2.2.8], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][Apache/2.2.8 (Ubuntu) DA
V/2], IP[192.168.15.12], PHP[5.2.4-2ubuntu5.10], Title[Metasploitable2 - Linux], WebDAV[2], X-Powered-By[PHP/5.2.4-2u
buntu5.10]

(mohamed@moahmed)-[~]
$ nikto -h http://912.168.15.12
- Nikto v2.5.0
-----

+ 0 host(s) tested
```

Vulnerability Summary Table

<i>Vulnerability</i>	<i>Description</i>	<i>Risk Level</i>	<i>Example Impact</i>	<i>Evidence</i>
Anonymous FTP Login	FTP allows login without credentials	High	Data exposure; file manipulation	FTP banner + successful anonymous login
SMB Null Session	Guest access permitted on SMB shares	High	Information disclosure; lateral movement	smbclient output
Outdated Apache Server	Running Apache 2.2.8 with known CVEs	Medium	Exploitable web-based attacks	WhatWeb/Nmap detection
Telnet Service Enabled	Plaintext authentication available	Medium	Credential interception	Nmap service scan
Outdated SSH Version	OpenSSH 4.7p1 running	Medium	Potential weaknesses in authentication	Nmap version detection

Risk Rating Methodology

For rating the level of identified vulnerabilities, there was the use of the qualitative risk rating. It considers the following factors: likelihood, impact, and exploitability.

Likelihood refers to how easily an assailant can exploit it, impact considers the potential loss the organization can suffer in terms of data loss or disruption of services, and exploitability denotes how technically challenging or easier it was to exploit.

Vulnerabilities that scored high in these factors were considered High Risk threats, while Moderate Risk threats scored moderately. It fits well in the process of penetrating the organization in order to help ESN know what to tackle first.

Rule: Countermeasure retesting

After these discoveries, two changes were applied as countermeasures. One was disabling anonymous login through FTP. Afterward, any reconnect attempt using

anonymous login was immediately denied, proving the effectiveness of the solution applied. In addition, limiting guest shares in SMB was applied as another countermeasure. After changing the configuration, smbclient -L //192.168.15.12 required actual logins and the list of shares was no longer accessible through anonymous login. These reconnection tests demonstrate how proper configuration can make security much more effective despite having many vulnerabilities.

New user interface creation In the event that an attacker had shell access with the compromised Linux computer, they could maintain that level of access by creating a new user account with greater privileges. In many cases, such an individual could modify the system account database or administer the accounts using an administration tool. For instance, the hacker could generate a new user account, assign it a password, and grant it privileges to operate in any of the “sudo” or “root” groups. They could then gain access at any time despite having patched the exploit. Further, the hacker can configure the SSH to enable password login for the new user. In this manner, the login process using regular OS operations and not the initial vulnerability makes detection difficult for the defenders.

```
(mohamed@mohamed)-[~]
$ sudo useradd Mohamed_EC1713487

(mohamed@mohamed)-[~]
$ sudo passwd abc123123
passwd: user 'abc123123' does not exist

(mohamed@mohamed)-[~]
$ sudo passwd Mohamed_ec1713487
passwd: user 'Mohamed_ec1713487' does not exist

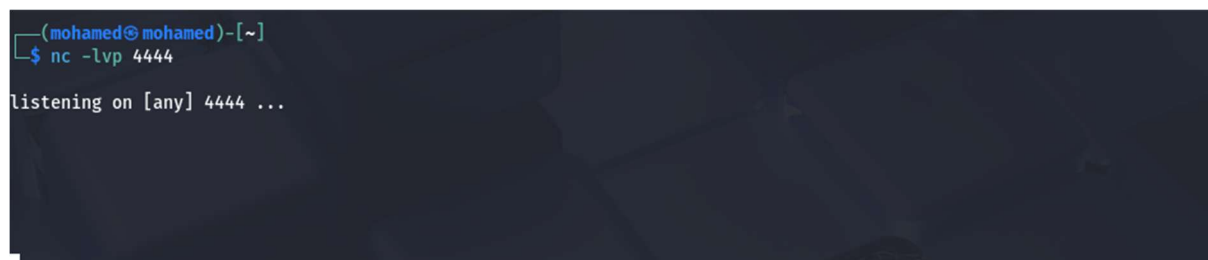
(mohamed@mohamed)-[~]
$ sudo passwd Mohamed_EC1713487
New password:
Retype new password:
passwd: password updated successfully
```

```
(mohamed@mohamed)-[~]
$ cat /etc/passwd | grep Mohamed_EC1713487
Mohamed_EC1713487:x:1003:1003::/home/Mohamed_EC1713487:/bin/sh
```

Maintaining the access

If the hacker manages to breach the target computer system, they can maintain the breach by using a constant talk channel through Netcat. Netcat can act as a tool in computer networks by opening up connections through TCP or UDP, listening at specified ports, or transferring data from one point to another. For bad uses, the hacker can use Netcat installed in the target computer to listen at a specified port and wait for connections. In such cases, the hacker can gain reconnection to the compromised computer without having to complete the initial hack. The process can involve the target computer initiating an outbound connection to another computer under the control of the hacker. In such cases, because it appears as usual network traffic, sometimes it can bypass the firewall or the access list, hence becoming a popular trick in pen-test demonstrations.

After the connection was established, the hacker could issue commands, transfer data, or manage the target computer from a distance. These scenarios hinge upon the capability of Netcat to transmit data from or to other computers using the network. They can apply the plan without any damage or installing permanent backdoors without using Netcat without negatively affecting the target computer or leaving any trace of the installation of persistent remote backdoors. They can exhibit innocent listeners or sysadm communication.

A terminal window with a dark background. The prompt is (mohamed@ mohamed)-[~]. The user has entered the command nc -lvp 4444. The output shows 'listening on [any] 4444 ...' followed by a large block of redacted content represented by black boxes.

```
(mohamed@ mohamed)-[~]  
$ nc -lvp 4444  
listening on [any] 4444 ...  
[REDACTED]
```

Covering Tracks

An attacker attempting to breach the system will attempt to cover up any activity they have undertaken, so they aren't discovered. Therefore, they will cover up any trace evidence, remove any log entries, and modify timestamp dates so it isn't traceable. In a Linux distribution, the target will be shell history recordings, authorized login entries, and service entries. They will attempt to cover up or modify entries from auth.log or syslog files or from the user's personal shell history file. They would attempt to remove temporary files from any attacks or modify timestamp dates using standard tools found in the OS. Erasing any logs can result in damage to the actual OS, as such tasks are considered unethical, so I won't go through those procedures.

One such trick might involve redirecting the output of commands so that the malicious activity does not make its way into the logs. For example, instead of writing the commands to the shell history files, attackers can make use of certain options or begin shells that do not record activity. They can further make use of encrypting channels or redirect ports to evade security tracking. In highly sophisticated attacks, they might alter audit mechanisms to prevent logging or make use of imitation log files. In our test, rather than deleting or modifying any logs, we simply demonstrated how such logs can be reviewed by investigators to reveal questionable activity.

```
(mohamed@mohamed)-[~]  
$ cat /var/log/auth.log
```

```
(mohamed@mohamed)-[~]  
$ cat ~/.bash_history
```

```
(mohamed@mohamed)-[~]  
$ cat /var/log/syslog
```